

Day 1 - Penetration Testing Executable Standard (PTES)

It is a framework used to define the structure of the pen-test. It includes 7 important aspects.

1. Pre-Engagement Interaction

Handles with the scope, Rule of Engagement(RoE), Time estimation with padding (20%). Legal agreements has to be signed before testing. Tester has to be the guide as the client wouldn't be sure of their complete requirements. Daily updates, start time, deadline should be discussed. Testing third-party shouldn't be done. Cost estimation should depend on the volume and type of work.

2. Intelligence Gathering

Reconnaissance against target. Find as many potential entry points. 3 levels of information gathering.

Level 1 (compliance driven, automated testing)

Level 2 (Best practice, incl automation and manual analysis)

Level 3 (red team scoped, deep manual analysis)

OSINT (Open Sourced Intelligence), making use of publicly available information

Passive, Semi-passive, Active

HUMINT (Human Intelligence), Footprints (Internal and External)

3. Threat Modeling

Represent threats, it severity. Focused on 2 factor: Asset (business asset and process) and Attacker (threat community and capability).

Business Asset: organization data, human asset

Business Process: infrastructure and data processings

Threat community: Internal and External Threat

Capability: exploits and tools used

4. Vulnerability Analysis

Process of analyzing flaws, misconfigs, insecure designs, etc. 4 category:

Active Testing: network scanning, protocols, manual and tools testing

Passive Testing: metadata analysis, traffic monitor

Validation: attack tree, testing in isolated environment

Research: research of the exploit and vulnerability, public and private research

5. Exploitation

Exploit the vulnerability, bypassing security restrictions without alarming the IDS, IPS, Firewall, etc.

Payload obfuscation, Bypass system protection, Web Application Firewall (encoding the request), etc.

6. Post Exploitation

Determine the value of a compromised machine. Adhere to RoE, Infrastructure analysis, exfiltration, further testing in other infrastructures, and final clean up.

7. Reporting

Executive summary, overall posture, recommendation summary, risk assessments.

Technical report: information, vulnerability assessments, risk, exposure, exploit reports, conclusion.